DEGREE PROJECT FOR MASTER OF COMPUTER SCIENCE WITH SPECIALIZATION IN CYBERSECURITY DEPARTMENT OF ENGINEERING SCIENCE UNIVERSITY WEST

Cybersecurity vulnerabilities and attack detection in environmental sensor networks

An experimental study

Christopher Salame
Mohammad Antor

UNIVERSITY WEST

A THESIS SUBMITTED TO THE DEPARTMENT OF ENGINEERING SCIENCE
IN PARTIAL FULFILMENT OF THE REQUIREMENTS FOR THE DEGREE OF
MASTER OF COMPUTER SCIENCE WITH SPECIALIZATION IN CYBERSECURITY
AT UNIVERSITY WEST
April 22, 2026

Author(s):	Christopher Salame
	Mohammad Antor
Examiner:	Lefteris LASTNAME-MISSING
Supervisor:	Fatiha Djebbar, Amit Mishra
Program:	Master Programme in Cybersecurity
Main field of study:	Computer Science
Credits:	60 Higher Education credits
Keywords:	Word1, Word2, Word3, Word4, Word5
Template:	University West, IV-Master 2.10
Publisher:	University West, Department of Engineering Science
	S-461 86 Trollhättan, SWEDEN
	Phone: + 46 520 22 30 00 Fax: + 46 520 22 32 99
	Web: www.hv.se

Summary

The student must write a summary with a short background and the major results and conclusions. A summary presents all the major elements of the thesis in a highly con-densed form and should therefore not exceed half a page. A common error is to fail in presenting the result. The main purpose of the thesis is to explain your discovery and how you reach that, not all steps you did present as a diary.

Preface

Affirmation

firstname aftername	Date
firstname 2 aftername 2	Date

Contents

1 Introduction **1**
1.1 Motivation . . . 2
1.2 Aim . . . 2
1.3 Research questions . . . 3
1.4 Contributions . . . 3

2 Background and Related Work **5**
2.0.1 Network Architechture . . . 6
2.0.2 Communication Protocols and Standards. . . . 8
2.0.3 IoT communication protocols and protocol stack . . . 9
2.1 Cyber Threat Landscape and Attack Surfaces . . . 10
2.1.1 IoT-Specific Threat Characteristics . . . 10
2.1.2 The STRIDE Threat Modeling Framework . . . 12
2.2 Threat Modeling . . . 12
2.2.1 Assets Identification . . . 13
2.2.2 Vulnerabilities . . . 13
2.2.3 Threats . . . 13
2.2.4 Architectural Decomposition and Data Flow . . . 14
2.3 Intrusion and Anomaly Detection in IoT . . . 14
2.3.1 Machine Learning Methods . . . 15
2.4 Regulatory and Standards Landscape . . . 17
2.5 Complementary Mitigations . . . 17
2.6 Challenges and limitations . . . 17
2.7 Related work . . . 18

3 Research Methodology **20**
3.1 Research Design . . . 20
3.1.1 Addressing Research questions . . . 21
3.2 System Architecture Definition and Security Issues Identification . . . 22
3.2.1 Selection of Dataset . . . 22
3.2.2 Data Gathering Methods . . . 22
3.3 Threat Landscape Analysis and Classification . . . 23
3.3.1 Selection of STRIDE Framework . . . 23
3.3.2 Threat Modeling Procedure . . . 23
3.4 Security Control Identification and Mitigation Strategy Design . . . 24

3.4.1 NIS2 Article 21 Compliance Mapping 24
3.5 Machine Learning for intrusion detection 24
3.5.1 Selection of Machine Learning Algorithm 24
3.5.2 Experimental Procedure and Setup 25
3.6 System evaluation 26
3.6.1 Evaluation Metrics and NIS2 Alignment 26

4 Security Analysis and Framework Design 27
4.0.1 Dataset Description 27
4.0.2 Threat Classification 27
4.0.3 NIS2 Article 21 Compliance Mapping 28
4.0.4 UMAP of attacks 34
4.0.5 Heatmap of attacks 36

5 Results and discussion 37

Conclusion 38
5.0.1 Future Work and Research 38
5.0.2 Critical Discussion 38
5.0.3 Generalization of the result 38

Bibliography 39

1 | Introduction

Internet Of Things (IoT) is increasing across the world at a rapid speed, because of the increasing possibilities IoT contributes to several aspects of life. IoT makes several things in life easier and more efficient, but this also increases the vulnerabilities if not designed securely. Previous studies highlight that in this rapid speed of development of IoT, it needs to be monitored to limit harmful impacts [1]. It is also evident that attacks could be mitigated in sensitive IoT environments by following NIST 800-53 controls or even prevented entirely where IoT got compromised [2]. Another attack on a Norwegian dam demonstrates how fragile IoT can be in critical infrastructure, showing that the internet is exploding with internet-exposed devices within control systems without modern protections. The study mentions that at least 23 000 automation IoT connected systems are vulnerable to similar compromises [2]. This highlights the risks and shows that cybersecurity within IoT is important to work with both protectively and reactively to prevent and mitigate this kind of attacks [3]. Previous studies highlight also that IoT often are manufactured without strong cyber security in mind, leading it to be vulnerable that increases the risk of attacks [4]. Deep learning approaches have been a successful way of mitigating such as attacks, detecting up to 99.94% of the attacks [5].

In addition, Intrusion Detection System (IDS) with Machine Learning (ML) have increasingly been adapted, because of accurately identifying attacks by having high performance, high accuracy, and effectiveness against several types of attacks [6]. Another study shows the importance of using ML within IDS to prevent and identify attacks, with accuracy above 90 percent when used and tested. This highlights even more about how ML and IDS within IoT could add necessary protection for different types of attacks [7]. Studies have examined how well the IEC/ISO 62443 standard applies to Industry 4.0 and IoT environments, showing that it provides a solid security framework to prevent common attacks for IoT. This highlights how important it is to follow ISO 62443 standards when using IoT in sensitive environments [8]. Although ISO standards are voluntary, the EU has mandated the NIS2 Directive, which EU Member States must transpose into national law. Compliance with standards such as ISO 27001 and ISO 62443 can help meet several of NIS2's cybersecurity requirements, including risk management and incident reporting. NIS2 obliges entities in critical sectors to implement these measures throughout their organizations [9]

This paper addresses these challenges through three connected steps. First, cyber threats specific to environmental IoT sensor networks are systematically identified and categorized using the STRIDE framework, grounded in real-world attack data from the Edge-IIoTset dataset [10]. Second, machine learning models are trained and evaluated on that same data to assess how well they can detect attacks such as DDoS under realistic hardware

constraints. Third, the resulting threat-mitigation framework is mapped directly to the technical requirements of NIS2 Article 21, using the ENISA implementation guidance [11] to verify compliance. These three steps build on each other: the threat taxonomy shapes which attacks the ML models target, and the detection results form the technical evidence used to assess NIS2 alignment.

1.1 Motivation

Environmental sensors that monitor water quality send important information directly into decisions about public health. However, the Internet of Things (IoT) devices that run against these sensors are at risk of being attacked. Hackers can steal data, take down networks, or introduce false readings that can confuse emergency responses and influence policy choices. Around 250 million cases of water related diseases is estimated annually, with around five to ten million leading to death, worldwide making water a critical sector [12]. This also falls under NIS2 directive as critical infrastructure and needs to follow and implement NIS2 in order to increase security [13].

The challenge is that these sensors operate with very limited resources in remote areas and collect data that follows a set pattern [14], [15]. While this makes it easier to detect issues, it also makes them easy targets if attackers know how these systems work. Introducing machine learning can help mitigate attacks in IoT [5].

Current IoT security solutions don't fit well with the tight constraints of these systems. NIS2 directive provides strong security guidelines for critical infrastructure [13], but challenges may lie by implementing them on constrained IoT devices that present real life performances.

With the EU's implementation of NIS2 as a legal requirement, critical sectors such as water treatment are now required to meet stricter operational and cybersecurity standards [13]. These obligations also extend to their IoT devices and environmental sensors.

However, there is still an open question that has not been fully examined: whether real-time security measures can realistically be implemented given the limited computational capacity and operational constraints of these devices.

Previous research shows that machine learning–based intrusion detection systems (IDS) have achieved strong detection rates in general IoT environments. Our work, however, takes a more targeted approach by focusing specifically on water quality as a critical sector under NIS2.

We investigate whether it is possible to comply with NIS2 requirements and established standards while accounting for the inherent resource limitations of IoT devices and environmental sensors, and still remain fully aligned with the directive's security expectations.

1.2 Aim

The aim is to design and evaluate a machine learning-based intrusion detection system for environmental IoT sensor networks that effectively identifies and mitigates cyber-attacks

such as denial-of-service in water quality monitoring systems, while ensuring the security framework aligns with the requirements of the NIS2 Directive.

1.3 Research questions

1. What are the primary cyber threats to environmental IoT sensor networks, and how can they be systematically categorized?

   This is addressed by applying the STRIDE framework to the three-layer IoT architecture and validating the resulting threat categories against labeled attack traffic in the Edge-IIoTset dataset [10]. The output, a structured, layer-by-layer threat taxonomy, directly determines which attack types the ML models in RQ2 are trained to detect.

2. How effectively can ML-based intrusion detection and anomaly detection identify cyber-attacks (such as DDoS) in resource-constrained environmental sensor networks using real-world IoT datasets?

   This is addressed through experimental evaluation using two complementary datasets: Edge-IIoTset [10] for network-level attack detection, and the Kaggle water quality dataset [15] for sensor-level anomaly detection. Models are evaluated using F1-score and balanced accuracy to account for class imbalance, and against realistic RAM budgets for constrained devices. The attack classes targeted come directly from RQ1, and the detection outcomes feed into RQ3.

3. To what extent can the proposed security framework for environmental sensor networks satisfy the technical and procedural requirements of the NIS2 Directive?

   This is addressed by mapping each identified STRIDE threat and its corresponding ML-based countermeasure to the specific subclauses of NIS2 Article 21(2) [13], using the ENISA Technical Implementation Guidance [11] as an interpretive reference. The ML detection results from RQ2 serve as the technical evidence for whether the countermeasures are sufficient to meet each clause.

1.4 Contributions

Scientific and Practical Contribution:

- Demonstrates how open environmental datasets can be secured using ML-based methods.
- Provides a reproducible attack and defense pipeline for environmental IoT systems.
- Bridges the gap between technical intrusion detection and industry standard cybersecurity requirements.

Target Audience:

- Researchers in IoT and cybersecurity.

- Environmental monitoring system designers.
- Policymakers and engineers concerned with secure environmental data reporting.

The work is relevant because compromised environmental data can directly impact public health decisions, regulatory compliance, and trust in monitoring infrastructures.

2 | Background and Related Work

To monitor water quality and other essential environmental parameters, environmental sensors networks have become important element of infrastructure. These networks contain distributed IoT devices [1]. Generally, they collect data from remote locations and transfer it through wireless protocols. This way, it can help to analysis and take initiative to make decisions based on the transmitted data. However, the systems can be exposed by the same connectivity and can lead to significant cybersecurity risks [3].

Environmental IoT networks are increasingly utilized as a critical infrastructure for sustainable development, enabling real-time monitoring and proactive response to changes [1], [16]. Internet of Things changed the way we monitor and manage environmental resources. Water quality, temperature and pollution levels can be tracked by IoT enabled sensor networks with the help of continuous tracking parameters [1]. This technology involves integrating portable sensors, computing devices and internet communication infrastructure to monitor and control physical objects remotely [17], [16]. At its core, the IoT bridges the gap between the cyberspace and the practical world, allowing physical things such as water tanks, soil or industrial machines to communicate data to people and other machines at any time and place [17], [18]. These systems are typically structured into a multi-layered architecture composed of a physical sensing layer for data collection, a network layer for transmission and an application layer for data processing under user interaction [17], [19], [16].

Sensing and actuation hardware

Environmental IoT networks, particulary those used for smart water monitoring, rely on a diverse array of specialized hardware. The physical layer consists of nodes that use sensors to digitalize the physical states such as temperature, location and chemical composition [17]. Frequently employed resources for managing water are for example ultrasonic sensors, magnetic float sensors, water flow sensor, light detection and ranging sensors (LIDAR) to measure water depth and levels [16]. Beyond monitoring these, systems also integrate actuators such as valves and relays which allows the system to perform autonomous physical actions such as auto refilling a tank or shutting off a pump [16].

Communication infrastructure

The connectivity within these networks is based on the required range and power [20], [18].

- Short-range (WPAN): Used for local interaction, standards like IEEE 802.15.4, Bluetooth Low Energy (BLE) nad ZigBee are common [20].
- Long-range (LPWAN): Used in remote deployments, technologies such as LoRaWAN and SigFox are often used for their ability to transmit small amount of data over vast distances with minimal energy [20], [1].
- Internet access and secure tunnels: To relay data from a field gateway to a remote data center or cloud platform. Systems use mobile networks for example GSM, GPRS, or 3G/4G [20], [16].

Secure communication is often achieved through the creation of VPN tunnels or IPsec protocols, which establish encrypted pathways over public infrastructure to protect sensitive measurement data [19], [20].

Practical constraints and environmental challenges

Environmental IoT networks operate under severe practical limitations that fundamentally define their security and operational needs [20], [19]:

- Resource-constrained hardware: Most physical sensors are built with low cost 8 or 16-bit microcontrollers which possess limited memory and processing power [17], [16]. These devices are often incapable of supporting the heavy computational burden of standard IT security measures and encryption and the full TCP/IP protocol stack [17], [19].
- Energy constrains: Sensors are typically powered by non-rechargeable batteries or small solar panels, requiring them to stay in deep-sleep or idle modes for the majority of their operation to preserve their power source [18], [1], [16].
- Conditions: The hardware is often physically exposed to extreme environments, such as underground mines, remote forests, coastal areas [18]. This exposure leads to unique physical challenges such as high susceptibility of devices to physical tampering or capture by an adversary [19].

These technical and environmental limitations significantly expand the attack surface, as for example resource exhaustion through denial of service (DoS) can permanently disable remote infrastructure [19].

2.0.1 Network Architechture

IoT can be explained with several models differing from each other, there is no standard model that is agreed on that defines the layers of IoT [21], [14], [22] , [17]. The most common between all models is that all have physical and application layer, but in between it can differ from as simple as network layer to more in depth layers that is part of the network layer [14], [17]. Most research models share a core functional vision that bridges the gap between the physical world and cyberspace while some models expand into four or

five layers to include specialized functions. Researches generally agree on a foundational three-layer structure [14], [17], [19]. Typically we can see 3 basic layers; Physical layer, Network layer, and Application layer [14] as illustrated in Figure 2.1. Typically, sensors form a wireless network that transmits data through a gateway to a cloud platform [20].

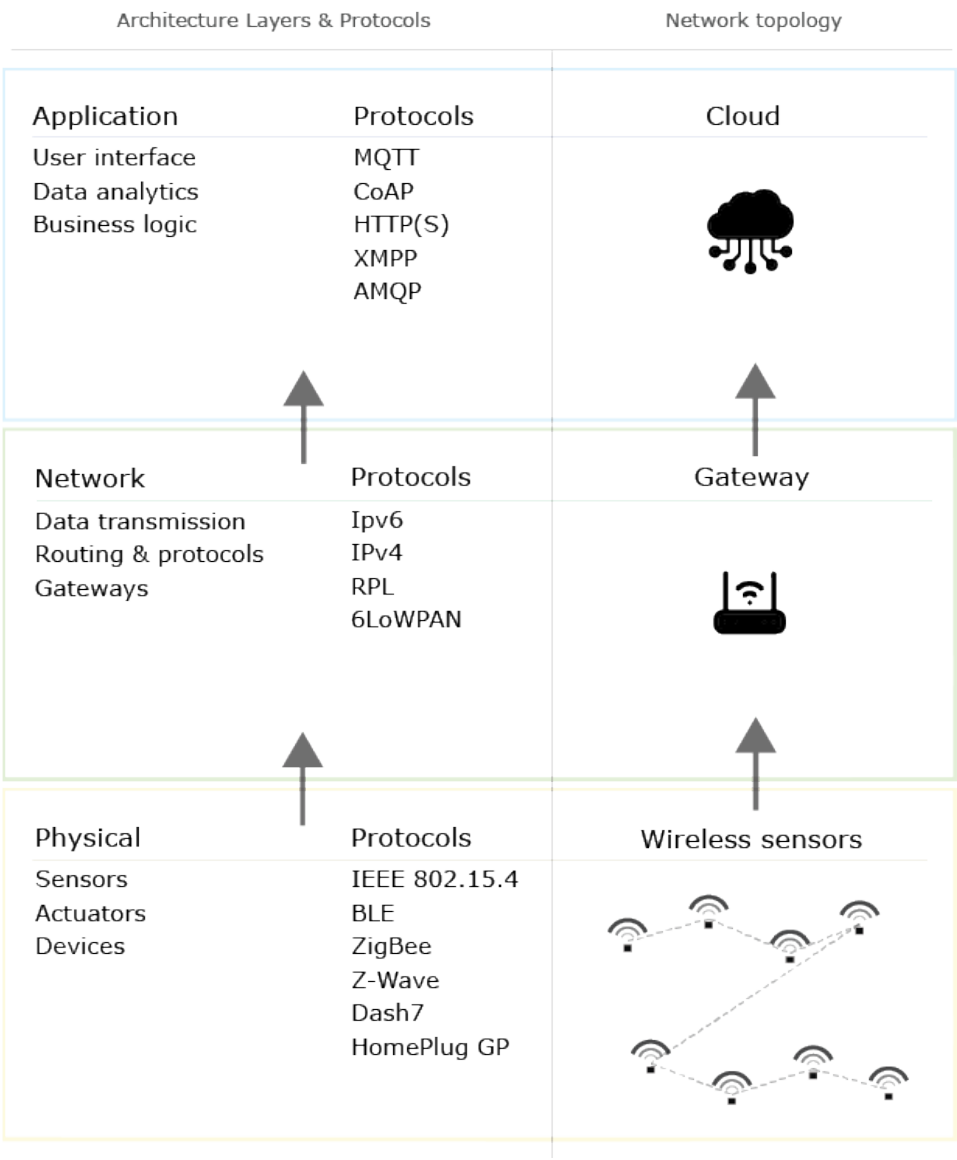

Figure 2.1: Layers of the Internet of Things architecture

1. Physical layer: In IoT architecture, the physical layer sits at the very base and it works with the actual hardware for example sensors, actuators as well as other connected devices. Device identification and enabling service discovery within the network are its main task [14].

2. Network Layer: The network layer uses numerous communication protocols to operate how data moves from one layer to another. When a physical device produces reading

for example an infrared sensor, the data goes through the network layer. Then the data is processed and forwarded to the upper layer, in this case Application layer [14].

3. Application layer: This layer is basically where an end user interacts with the system. This could be web dashboard, mobile app or any other interface. It sits on the top of the infrastructure and is accessible over the internet [23].

While these layers provide the structural framework for IoT systems, their practical functionality is enabled by specific protocols designed for resource-constrained environments. The specific communication protocols and security standards employed at each of these layers are described in detail in the next section.

2.0.2 Communication Protocols and Standards.

IoT devices rely on various communication technologies to transmit data between devices and cloud platforms. Each technology has trade-offs in terms of range, bandwidth, power consumption, and security [16], [18]:

- Short-range protocols (device to gateway): For short-ranged, device to gateway communication, BLE (Bluetooth Low Energy), Zigbee and LoRa (for long range, low power communication) are the most common options.

- Iot/cloud connection (gateway to cloud or device to cloud): Wifi and cellular the most common choice when it comes to connecting gateways to the cloud. Wifi offers supports security through WPA2/WPA3 and TLS. For cellular, the options consist of GSM, GPRS, LTE and NB-IoT. These enable remote connectivity and support SIM based authentication along with TLS encryption.

A more detailed examination of the individual communication protocols employed between sensors and gateways is presented below [16]:

- Wi-Fi: This is widley used for connecting sensor nodes or gateways to local routers to upload data to cloud servers.

- GSM/GPRS: Frequently employed for remote monitoring where local Wi-fi may not be available. It allows systems to send data to cloud platforms.

- LoRaWAN: It is utilized for long distance data transmission, it can handle up to 16km in line-of-sight conditions and is highly effective for large-area monitoring where traditional wifi range is insufficient.

- Bluetooth and BLE (Bluetooth low energy): is often used for short-range communication between sensors and master nodes for local user interfacing.

- Zigbee: This is a common choice for wireless sensor networks (WSN) to faciliate communication between multiple sensor nodes and a central gateway.

- nRF24L01 and RF433: Is used as viable wireless channels for transmitting processed sensor data to a main station.

The essential security controls associated with these protocols are listed below [16]:

- Limited computational resources in IoT devices restrict the use of heavy encryption.
- Wireless channels are exposed to eavesdropping, replay, and injection attacks.
- Protocol choice impacts both performance and security. IoT/cloud protocols for example MQTT over TLS or HTTPS help ensure data integrity.
- Proper gateway design is critical for enforcing security policies and detecting anomalies in transmitted data.

2.0.3 IoT communication protocols and protocol stack

Each layer relies on its own set of protocols. The IoT protocol stack applied in this scenario is shown in Fig. 2.1. Various protocols function at different layers, and each one brings its own security implications.

At the highest level there is application layer that enables interaction between the under-user, application and the gateway. The most common protocols that is used is listed below [22]:

- IPv4: is used at the network layer to enable data transfer within private IoT sensor clusters located behind a firewall. Hardware limitations is the leading cause for relying on IPv4 because typical microcontrollers often lacks the processing capacity to run the full TCIP/IP v6 stack, because it is more demanding [19].
- CoAP (Contstrained application protocol): is a lightweight request/response protocol that operates over UDP, ideal option for local network communication where reducing communication overhead is critical.
- MQTT (Message queue telemetry transport): This is a publish/subscribe protocol running on TCP. It is often described as highly efficient for battery operated devices and remote communications.
- XMPP (Extensible messaging and presence protocol): This is often used and suited for consumer oriented applications , such as instant messaging and chatting due to its strong security and device addressing.
- AMQP (Advanced Message Queuing Protocol): This is primarily used for passing business messages between applications across different platforms.

One level down, on layer 2 (Network layer) there is other protocols used, these handle how data packets are addressed and moved across the network [22]:

- 6LoWPAN: A scalable and secure protocol designed to encapsulate IPv6 packets for low-power, small devices with limited processing capabilities.
- RPL (Routing Protocol for Low-Power and Lossy Networks): The most commonly used routing protocol for these environments, providing both upward and downward route discovery.
- IPv6: Provides the foundational identification and location system for routing traffic across the internet.

Physical Layer Protocols [22]: These manage the transmission of data across physical links.

- Short-Range Wireless: Includes BLE (Bluetooth Low Energy), Z-Wave, and HomePlug GP (useful for reliable LAN and home automation).
- Longer-Range/Scalable Wireless: Includes ZigBee and Dash7, which are noted for supporting wide network topologies for smart homes and healthcare systems.

IEEE 802.15.4-2006 is often seen as the sufficient standard for meeting energy efficiency requirements at the physical level.

Protocol stack in IoT systems

Most IoT systems uses different protocols on different layers. IoT systems for environmental sensor networks typically follow a three-layer protocol stack consisting of Physical, Network, and Application layers, as illustrated in Figure 2.1. This architecture enables data flow from resource-constrained sensors to cloud-based analytics, but also introduces security vulnerabilities at each layer relevant to NIS2 requirements for critical infrastructure [13].

2.1 Cyber Threat Landscape and Attack Surfaces

Environmental IoT sensor networks can face various types of attack at any layer of the network architecture and different types of harm can be done by these attacks [24].

Table 2.1 shows different types of attack that is possible depending on each different layer in IoT.

2.1.1 IoT-Specific Threat Characteristics

Explain why IoT threats are different from conventional network threats, the combination of physical accessibility, weak authentication due to constrained devices, unpatched firmware, and scale makes IoT environments uniquely vulnerable. This sets up the need for a structured classification approach.

Unlike traditional IT systems, standard end-to-end security protocols (such as SSL/TLS and IPsec) are often suboptimal or inapplicable for IoT because they were not designed for the severe resource limitations of 8-bit or 16-bit microcontrollers [14], [17], [19].

Table 2.1: IoT Layer Attacks in Sensor-Based Systems

Layer	**Threats**	**Description**
Physical Layer	Physical Tampering	Attackers can physically access remote sensors, damage or modify them, steal security keys, or replace legitimate sensors with fake ones. This is critical for systems monitoring environmental conditions. Hardware Security Modules (HSMs) and AI-based detection methods have been proposed, but they require significant computational resources [16], [25], [26].
	False Data Injection	Attackers manipulate sensor readings (e.g., heating a sensor) to produce incorrect data. This can lead to poor decision-making and missed environmental hazard warnings [27] [24].
Network Layer	DDoS Attack	Attackers flood the network with excessive traffic from multiple sources, overwhelming bandwidth and computational resources, preventing the system from processing legitimate sensor data [14], [28].
Application Layer	Malware	IoT devices can be infected with malware such as viruses or spyware. Compromised devices can be controlled remotely and used to launch further attacks, as demonstrated by the Mirai botnet [28], [29].
	Web Vulnerabilities	Web interfaces and applications may suffer from vulnerabilities such as SQL Injection (unauthorized database access or modification) and Cross-Site Scripting (XSS), allowing execution of malicious code in users' browsers [29], [30].

Most peripheral nodes use 8-bit or 16-bit microcontrollers that lack the processing power and memory required to implement "deep layered security" or heavy cryptographic encryption . This leads to false access control, where systems rely on ineffective authentication or default passwords (e.g., "admin") that users rarely change [19], [16].

Standard security solutions are deemed unsuitable for dynamic, large-scale IoT environments that require autonomous operation for months or years without power recharge [14], [19].

Because IoT security requirements are highly domain-dependent and varies, previous studies argue that current research lacks a comprehensive and universally accepted standard for modeling IoT security properties [21].

Existing threat models are often too simplistic and are not easily reused for real-world production systems [21].

Consequently, there is an urgent need for a well-defined security threat classification such as taxonomies categorizing attacks into physical, network, software, and encryption types to provide a robust framework for identifying and mitigating challenges before deployment [14]. Utilizing structured models like STRIDE early in the design process is identified as essential

for analyzing diverse components and data flow vulnerabilities in complex environments [31].

Previous studies argue that systematic frameworks such as STRIDE are essential to capture the diversity of threats across all layers of the architecture and to prioritize security efforts effectively during the design phase [14], [31].

2.1.2 The STRIDE Threat Modeling Framework

To systematically identify and categorize vulnerabilities within the environmental monitoring architecture, this report utilizes the STRIDE framework. Developed by Microsoft, STRIDE is a well-established, software-centric methodology designed to identify what can go wrong in a system by evaluating its components and data flows early in the design process [32], [33], [31]. The framework categorizes potential threats into six distinct areas. Each of its six categories aligns with a specific security property, providing a clear basis for analysing potential vulnerabilities [31]. A brief description of these categories is provided below:

- Spoofing: Attacking authentication by impersonating legitimate devices or users.
- Tampering: Compromising integrity through unauthorized modification of data.
- Repudiation: Undermining non-repudiation by enabling actors to deny their actions.
- Information Disclosure: Revealing confidentiality through unauthorized access to sensitive data.
- Denial of Service (DoS): Affecting availability by rendering systems or networks inaccessible.
- Elevation of Privilege: Bypassing authorization controls to gain illicit administrative capabilities.

STRIDE is particularly appropriate for systematic threat analysis in IoT contexts because it provides a structured and lightweight approach for analyzing diverse, interconnected components such as sensors, field gateways, and cloud services [31]. This is essential for environmental IoT networks, where complex interactions across multi-zone trust boundaries such as those between remote sensors and cloud analytics platforms create a vast and heterogeneous attack surface [31].

2.2 Threat Modeling

The rapid growth of the Internet of Things (IoT) has introduced significant architectural complexity, involving diverse device platforms, networks, and cloud services [21]. This complexity often leads to an expanded attack surface, making the identification of security requirements a resource-demanding task that typically requires specialized expertise [21]. Structured methodologies for identifying, categorizing and prioritizing security risks have become a central focus in current research [21], [31].

Threat modeling is a structured way of identifying and analysing potential security threats to a system before and during its design and implementation. It is widely used in software and networked systems to understand how an attacker could compromise assets, which components are most exposed, and where countermeasures are most effective [32]. In the context of IoT and environmental sensor networks, threat modeling is particularly important because devices are resource-constrained, geographically distributed, and often deployed in critical infrastructures, which increases the impact of successful attacks.

2.2.1 Assets Identification

Identifying and prioritizing assets by their importance is essential, as it enables organizations to allocate resources effectively toward high-value assets (HVAs) that demand higher levels of protection. In addition, the level of priority assigned to an asset determines how resources are distributed and influences how strict and deep security controls are put in place. [34].

Assets refer to both physical and non-physical resources that provide value in supporting an organization's mission or strategic goals. Physical (tangible) assets include items such as equipment, buildings, machinery, communication networks, and personnel. Non-physical (intangible) assets encompass digital data, applications, embedded software, services, operational procedures, as well as an organization's brand, reputation, and individuals' privacy rights [34]. Within industrial control and cyber-physical systems (ICPS), assets are considered the systems, components, and services that malicious actors seek to exploit or disrupt [35].

2.2.2 Vulnerabilities

A vulnerability is a flaw in an asset, its functionalities, or its protective procedures that can be taken advantage of by a threat actor to carry out harmful operations [34], [35].

There is different types of vulnerabilities, for example technical weaknesses that are flaws or gaps in hardware or software that can be exploited by attackers. That could be for example vulnerabilities in firmware or servers, which may allow unauthorized access, system manipulation, or disruption of industrial processes. Such weaknesses can pose serious risks if not properly identified and mitigated [35].

Another critical area is supply chain vulnerabilities, where threats can emerge from limited component traceability, the introduction of counterfeit hardware or the insertion of malware by untrusted suppliers. These vulnerabilities can be exploited by attackers to compromise the integrity, confidentiality, or availability of industrial systems even before they are deployed within an organization [34].

2.2.3 Threats

A threat is any situation or event, such as a malicious act that takes advantage of a vulnerability that could negatively affect an organization's operations, assets, or personnel [34], [35].

Threats can be classified in different ways and categories, for example:

- External (Outsider): External threats come from individuals or groups outside the organization who do not have authorized access. These can include highly skilled adversaries such as nation-states, terrorist groups, or organized crime networks, often motivated by financial gain, political objectives, or strategic disruption [35].
- Internal (Insider): These originate from individuals within the organization who have authorized access to systems but misuse it for personal motives. Insider actions are often driven by financial gain, revenge, or personal pride, and can pose significant risks to operations and data security [35].
- Human vs. Technical Threats: Human threats includes both deliberate malicious actions and unintentional mistakes. Technical threats, on the other hand, come from equipment malfunctions, system failures, or environmental disruptions that can impact operations and security [34], [36].

Threat Categorization

One of the most commonly used threat modeling frameworks is STRIDE, originally proposed by Microsoft. STRIDE organizes threats into six categories; Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege. This classification helps designers reason about adversarial behavior in a structured manner and ensures that key threat classes are not overlooked during security analysis. In IoT systems, STRIDE can be applied to components such as sensor nodes, gateways, communication links, and cloud services to systematically enumerate possible attacks across the architecture [33].

2.2.4 Architectural Decomposition and Data Flow

A critical first step in threat modeling is the decomposition of the system into key components based on international standards such as ISO/IEC 30141 [21]. System views typically categorize assets into specific domains, including the Sensing and Controlling Domain (sensors, actuators, and gateways), the Application Service Domain (cloud analytics and storage), and the User Domain [21].

To visualize interactions, developers often employ Data Flow Diagrams (DFDs) to map the movement of data between components and identify critical trust boundaries [31]. Analyzing these flows across different zones such as the local user zone, cloud services zone, and remote user zone that is essential for pinpointing vulnerabilities specific to each layer of the infrastructure [31].

2.3 Intrusion and Anomaly Detection in IoT

Traditional IDS were designed for conventional networks with abundant computational resources, and those assumptions break down in IoT environments [6], [7]. Signature-based IDS compare network traffic against databases of known attacks, but environmental sensors typically carry only 4-32 KB RAM and 32-256 KB flash storage [14], which is far too little to store and process thousands of attack signatures in real time.

Rule-based anomaly detection struggles with environmental variability. Water temperature naturally fluctuates with weather and seasons, making static thresholds unreliable [15]. Rules loose enough to avoid false alarms let attacks hide within normal bounds. Rules strict enough to catch attacks generate floods of false positives [14].

Network-based IDS assume centralized monitoring over stable high-bandwidth connections, but sensor networks use constrained wireless protocols (BLE, Zigbee, LoRa) with intermittent connectivity, making centralized analysis impractical [20] [18].

A further issue, often overlooked in generic IoT IDS literature, is class imbalance. In environmental monitoring deployments, attack traffic represents a small fraction of total network activity. Standard accuracy metrics therefore give a misleadingly optimistic picture: a model that simply classifies everything as normal can reach 95%+ accuracy while detecting zero attacks. Evaluation in this domain should rely on F1-score and balanced accuracy, which give equal weight to both classes regardless of how often each appears [37].

2.3.1 Machine Learning Methods

Machine learning addresses these limitations by learning patterns from data rather than relying on predefined rules [28]. However, not all ML methods are practical for constrained devices, and the choice of algorithm involves a real trade-off between detection accuracy and deployability. Table 2.2 summarizes the key options

Table 2.2: Comparison of ML Methods for IoT Intrusion Detection

ML Method	**What They Can Do**	**What They Cannot Do**	**Deployment**
Classical Classifiers (Decision Trees, Random Forest, Logistic Regression)	Random Forest: up to 99.99% accuracy [28]. Decision Trees: 95–98% accuracy with microsecond inference [28], [37]. Logistic Regression fits within 4 KB RAM [28].	Require manual feature engineering [28]. Struggle with novel or sophisticated attacks. Need retraining when attack patterns shift [28], [37].	Can run directly on sensors or gateways [28], [37].
Ensemble Methods	Up to 99.97% accuracy by combining 3–5 classifiers [37]. Each model catches different attack types, improving overall robustness.	Resource requirements multiply with each added model. Sensors cannot fit multiple classifiers simultaneously [37].	Cannot run on sensors. Feasible on gateways (200–500 MHz, 256 MB+ RAM) [37].
Deep Learning (CNN, ANN)	Highest reported accuracy (99.9%+) [5], [7], [37]. Learns features automatically. CNNs capture spatial patterns; LSTMs capture temporal sequences.	Typically require 10–100 MB RAM [37], [38] — orders of magnitude more than sensors provide. High computational cost drains batteries within hours [38]. Black-box nature hinders interpretability.	Cannot run on sensors or gateways. Requires cloud or server infrastructure [5], [37].
Hybrid Architectures	Distributes detection across tiers: lightweight models on sensors, medium models on gateways, heavy models in the cloud [39], [37]. Adapts compute to threat severity.	Introduces communication overhead and latency between tiers. Requires reliable end-to-end connectivity [39].	Most practical for real-world deployments [39].

The table highlights a fundamental tension for this work. Deep learning models achieve the best raw detection rates but are entirely impractical for devices with 4-32 KB RAM. Deploying a CNN or ANN in a constrained sensor environment would require model compression techniques such as post-training quantization, weight pruning, or knowledge distillation to reduce both parameter count and memory footprint [37]. Without such measures, these models simply cannot fit on the target hardware, regardless of their reported accuracy. Classical classifiers, by contrast, can run at the edge but may miss sophisticated multi-stage attacks. This trade-off is central to RQ2 and directly influences how the results are interpreted against the NIS2 compliance requirements in RQ3.

2.4 Regulatory and Standards Landscape

The EU NIS2 Directive (Directive (EU) 2022/2555) establishes cybersecurity requirements for critical infrastructure across 18 sectors, including water management and waste management. This is directly relevant to environmental IoT monitoring systems. Essential entities must implement risk management measures, including policies on risk analysis, incident handling, business continuity, supply chain security, and continuous monitoring of network security. Significant incidents must be reported within 24 hours (Article 23), with management held personally accountable for compliance. Environmental sensor networks qualify as essential entities due to their role in public health and regulatory compliance [13].

Standards like ISO/IEC 27001 and IEC 62443 provide practical frameworks for implementing these requirements. IEC 62443 in particular was designed with industrial networked control systems in mind and maps well onto IoT environments [8]. While these ISO standards remain voluntary, compliance with them is widely recognized as a credible path toward satisfying several NIS2 obligations, including risk management and incident reporting [9]. This thesis examines the practical challenge of translating these high-level directives into concrete security controls on resource-constrained environmental sensor hardware.

2.5 Complementary Mitigations

Beyond ML-based detection, two additional techniques are relevant for environmental IoT networks. Blockchain can provide a tamper-evident log of sensor readings: because records are distributed and cryptographically linked, any modification of historical data becomes detectable [40], [39]. The main drawback is computational cost, which is writing to a blockchain requires processing that most sensor microcontrollers cannot sustain. Software Defined Networking (SDN) offers a complementary approach at the network level, giving administrators centralized visibility and the ability to push blocking rules to gateways when a DDoS attack is detected [41]. Neither technique eliminates the underlying trade-offs: stronger protection consistently comes at the cost of higher power consumption, more processing overhead, and greater system complexity [14].

2.6 Challenges and limitations

IoT devices usually run on small microcontrollers with limited memory and processing power, which makes traditional computer security methods difficult to apply effectively [42]. IoT also don't have a universal standard for consutrtion for the application layer, that leads to challenges in managing access permissions and identity authentication across different manufacturers [42].

One of the main reasons IoT devices tend to have weaker security is their limited processing power. For instance, strong encryption algorithms like AES are often too resource-intensive, so developers use lighter alternatives or specialized algorithms designed for low-power devices, sometimes at the cost of data confidentiality [14].

Another limitation is that IoT devices are often physically accessible, which makes them vulnerable to damage, tampering, and sleep deprivation attacks; where an attacker keeps a node awake to drain its battery [14].

2.7 Related work

The global implementation of Internet of Things (IoT) technologies is occurring at an intense speed with projections suggesting that over 125 billion devices will be connected within the next decade. This expansion is driven by the potential to simplify daily processes, improve system efficiency and enhance overall quality of life across sectors like industry, healthcare, and agriculture. However, while these advancements offer significant benefits, they also introduce critical security issues related to IoT networks and the management of security tools. Because many IoT devices are rapidly produced, they often lack robust protections, making them vulnerable to attacks [1]. Previous research emphasizes that this rapid development must be carefully monitored and evaluated to identify potential drawbacks and limit harmful impacts on society and the environment [1].

It is also evident that attacks could be mitigated in sensitive IoT environments by following NIST 800-53 controls or even prevented entirely where IoT got compromised [2]. Another attack on a Norwegian dam demonstrates how fragile IoT can be in critical infrastructure, showing that internet is exploding with internet-exposed devices within control system without modern protections. The ref. [3] mentions that at least 23 000 automation IoT connected systems are vulnerable to similar compromises.

This highlights the risks and shows that cybersecurity within IoT is important to work protectively not only reactive to prevent and mitigate this kind of attacks. Previous studies highlight also that IoT often are manufactured without strong cyber security in mind, leading it to be vulnerable and that leading to increased risks of attacks [43].

Deep learning approaches have been a successful way of mitigating such as attacks, detecting up to 99.94% of the attacks [5]. In addition, IDS (Intrusion Detection System) with ML (Machine Learning) have increasingly been adapted, because of accurately identifying attacks by having high performance, high accuracy, and effectiveness against several types of attacks. Another study shows the importance of using ML within IDS to prevent and identify attacks, with accuracy above 90% when used and tested. This highlights even more about how ML and IDS within IoT could add necessary protection for different types of attacks [37].

Previous studies have examined how well the IEC/ISO 62443 standard applies to Industry 4.0 and IoT environments, showing that it provides a solid security framework to prevent common attacks for IoT. This highlights how important it is to follow ISO 62443 standards when using IoT in sensitive environments [8]. Although ISO standards are voluntary, the EU has mandated the NIS2 Directive, which EU Member States must transpose into national law. Compliance with standards such as ISO 27001 and ISO 62443 can help meet several of NIS2's cybersecurity requirements, including risk management and incident reporting. NIS2 obliges entities in critical sectors to implement these measures throughout their organizations [9].

Existing taxonomies are largely generic and do not specialize in environmental sensor

networks, nor do they provide guidance on linking observed threats to regulatory controls, leaving a gap in both practical applicability and compliance-driven security planning [44].

Several AI-driven IDS approaches for IoT and wireless sensor networks report very high classification performance for DoS and other attacks. Yet, most studies either target generic wireless LANs or synthetic WSN scenarios rather than real-world environmental sensor networks, and only partially address constraints such as limited energy, processing capacity and memory on deployed nodes [38].

A recent systematic review of IoT security highlights attack detection as a central research area, with many solutions relying on ML and deep learning for network-level intrusion and anomaly detection, including DDoS and botnet attacks. The review also stresses limitations such as dataset scarcity, lack of standard evaluation practices and the difficulty of deploying heavy models on resource-constrained IoT devices, which motivates evaluating lightweight ML-based detection in realistic environmental sensor settings [45].

Recent studies have started paying more attention to security in resource constrained IoT systems, which is good news for the kind of work this thesis is doing. Alwaisi et al. propose a lightweight TinyML based machine learning approach to detect attacks that go after device resources like energy and memory and it actually works pretty well without demanding too much from the hardware [46]. That is encouraging because it shows that powerful machines are always needed to get decent security results [46]. The catch though is that the study does not really look at environmental sensor networks and it does not touch on regulatory requirements like NIS2 [46].

A study introduces a simulation framework that models heterogeneous IoT and edge environments including communication protocols, mobility and energy behaviour. This give researchers a realistic but controlled setting to test ideas without touching live systems [47]. This is genuinely useful when running attack experiments on real water monitoring infrastructure is simply not an option [47]. That said, IoTSim-Edge was not built with security in mind and does not include intrusion detection or security compliance analysis. This limits how far it can go for cybersecurity focused research [47].

A recent study reviews a deep reinforcement learning based framework for task offloading in resource constrained IoT networks that shows real improvements in latency and energy efficiency [48]. It is solid work on the resource management side of things. However, the focus stays on scheduling decisions rather than detecting or analysing cyber attacks. Therefore, the security side of IoT systems is largely left untouched [48].

One study is referring at AI techniques for resource constrained IoT devices points to approaches like knowledge distillation as a practical way to shrink larger models down to something that can actually run on limited hardware [49]. That is a useful insight because fitting capable models onto tiny devices is one of the real challenges this thesis keeps running into [49]. The study does not though go as far as testing intrusion detection or digging into real world IoT security scenarios. So while it lays some good groundwork, it does not quite reach the gap this thesis is trying to fill [49].

While technical performance and resource constraints are heavily researched, the integration of these technical solutions with specific regulatory requirements and their specific application to environmental sensor networks remain key areas for further exploration.

3 | Research Methodology

3.1 Research Design

This chapter describes the systematic approach used to investigate cybersecurity vulnerabilities in environmental IoT sensor networks and evaluate the effectiveness of machine learning-based detection mechanisms. Following the IEEE standard for engineering research, this section provides a structured, reproducible account of the experimental setup, data preparation, and evaluation procedures.

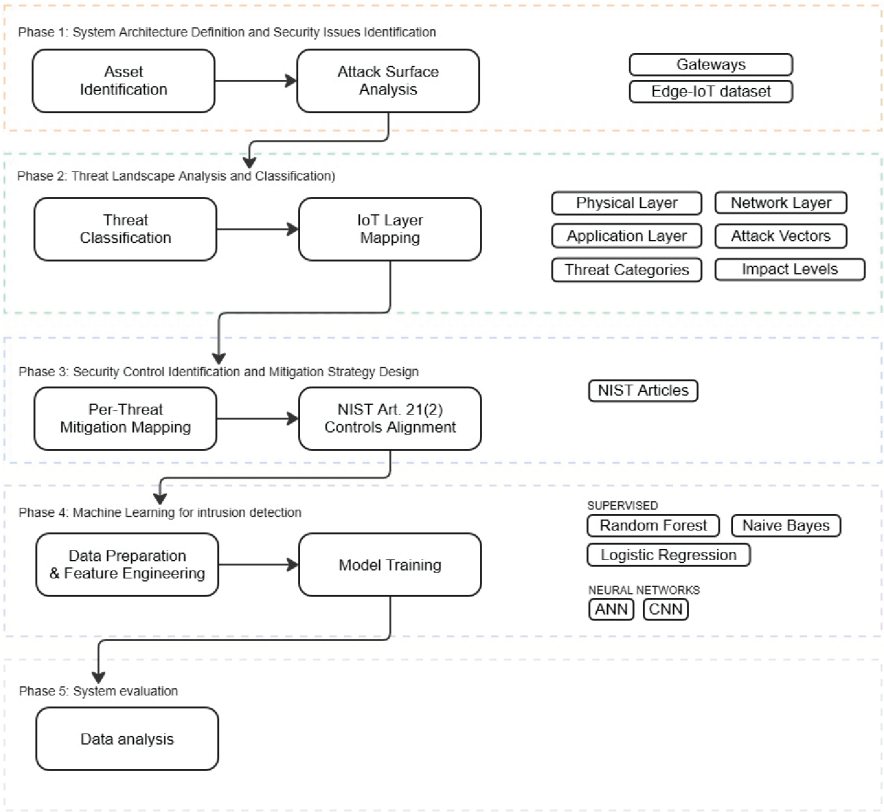

Figure 3.1: Project workflow overview illustrating the chronological phases of the research process.

The following diagram figure 3.1 illustrates the chronological phases of the research pro-

cess.

The study adopts an experimental and data-driven methodology, combining structured threat modeling with machine learning-based intrusion detection for environmental IoT sensor networks [21], [28]. Simulation based approach was chosen because it provides a controlled virtual environment that allows for modeling high intensity attacks (e.g DDoS) and routing related threats [10]. This also ensures that testing does not impact real world production systems or physical infrastructure [10]. This design enables the intentional manipulation of independent variables, such as attack types and intensities so that we can observe their causal effects on dependent variables like detection accuracy and system latency [37]. Simulation also permits reproducible experiments under controlled conditions, which would be impractical with live environmental monitoring systems serving critical infrastructure [34],[36].

3.1.1 Addressing Research questions

The three research questions are addressed sequentially, with each phase producing outputs that feed directly into the next.

RQ1 is addressed in Phase 1 and Phase 2. The system architecture is first decomposed into its three IoT layers (physical, network, application), and assets are identified at each layer following the ISO/IEC 30141 reference model [21]. The STRIDE framework is then applied element-by-element using PyTM [50] to enumerate threats at each trust boundary. The resulting threat taxonomy is cross-checked against the labeled attack categories in Edge-IIoTset [10] to confirm that the identified threats correspond to observed, real-world attack patterns rather than theoretical abstractions. The deliverable from this phase is a structured threat table mapping each STRIDE category to specific attack techniques, IoT layers, and affected assets.

RQ2 is addressed in Phase 4. The labeled traffic from Edge-IIoTset [10] is used for network-level intrusion detection, targeting the attack classes identified in RQ1 (DDoS, MITM, SQL injection, XSS, ransomware). Separately, the Kaggle water quality dataset [15] is used for sensor-level anomaly detection, specifically targeting false data injection. These are treated as two distinct experiments with different models and evaluation methods, as described in Section 3.2.1. Classical ML classifiers (Random Forest, Decision Tree, Logistic Regression, Naive Bayes) are evaluated for deployment feasibility on constrained hardware, while CNN and ANN models establish performance upper bounds when cloud processing is available. Model performance is measured using F1-score and balanced accuracy(not raw accuracy) to account for class imbalance in the attack traffic [37]. Memory footprints and inference times are also recorded to assess whether models can realistically run within a 4-32 KB RAM budget.

RQ3 is addressed in Phase 3 and revisited in Phase 5. Each STRIDE threat identified in RQ1 is mapped to the relevant subclauses of NIS2 Article 21(2) [13] using the ENISA Technical Implementation Guidance [11] as an interpretive reference. After the ML experiments are complete, the detection results from RQ2 are used to assess whether the proposed countermeasures are technically sufficient to satisfy each mapped NIS2 clause. This closes the loop between the three questions: threat identification informs model selection, and model performance determines NIS2 compliance.

3.2 System Architecture Definition and Security Issues Identification

3.2.1 Selection of Dataset

The research draws on two datasets that serve different and complementary purposes, treated as separate experiments rather than a single fused dataset.

The primary source for network-level intrusion detection is Edge-IIoTset [10], a large IoT security dataset collected from a real IoT testbed and containing labeled network traffic for 14 distinct attack types, including DDoS variants, MITM, SQL injection, XSS, and ransomware. It was selected because it provides protocol-level packet captures with ground-truth labels, enabling supervised classifier training directly on the attack categories that STRIDE analysis identifies as relevant to the network and application layers of the target architecture. A recognized limitation is that Edge-IIoTset captures generic IoT traffic rather than environmental sensor deployments specifically. Which means it lacks domain features such as water quality time-series, environmental parameter correlations, or the seasonal fluctuation patterns that characterize the monitoring systems this thesis targets.

To address the sensor-layer threat of false data injection, a second, separate experiment uses the real-time water quality dataset available from Kaggle [15]. This dataset provides legitimate sensor readings (pH, turbidity, dissolved oxygen, etc.) over time. Here the task is anomaly detection rather than classification: an unsupervised model is trained on the normal reading distribution, and injected anomalies, simulated by introducing statistical outliers consistent with sensor manipulation, are used to evaluate detection sensitivity.

These two experiments are not combined into a single pipeline. The network traffic experiment (Edge-IIoTset) evaluates how well ML classifiers detect attacks at the gateway and cloud layers. The time-series experiment (Kaggle water quality) evaluates how well anomaly detection identifies physically injected false readings at the sensor layer. Together they cover both threat surfaces identified in RQ1, even though no dataset currently exists that captures both simultaneously for real environmental sensor deployments.

3.2.2 Data Gathering Methods

The research utilizes a combination of open-source datasets to ensure realistic results:

- Environmental Data: Water quality time-series datasets obtained from Kaggle are used to represent legitimate sensor readings [15].

- Cyber-Attack Data: The Edge-IIoTset is utilized as a source of labeled cyber-attack traffic [10].

3.3 Threat Landscape Analysis and Classification

3.3.1 Selection of STRIDE Framework

There are several methodological reasons for selecting STRIDE as the threat modeling framework. First, STRIDE provides systematic coverage of all major threat categories (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege). It ensures comprehensive threat listing [21], [33]. Second, when it comes to threat categorizing with fundamental security properties (authentication, integrity, non-repudiation, confidentiality, availability, authorization), STRIDE is very effective and it creates clear mappings between threats and defensive measures [21]. Third, STRIDE has established effectiveness in IoT and cyber-physical system analysis, with extensive validation in prior research [21], [31], [32]. Finally, STRIDE is the optimal choice for addressing RQ1 (systematic threat categorization) because of its combination of comprehensiveness, structure and proven applicability to IoT systems.

3.3.2 Threat Modeling Procedure

This study employs a structured threat modeling methodology to systematically identify and categorize cybersecurity threats in environmental IoT sensor networks. The process begins with modeling a basic network setup representative of environmental sensors and IoT deployments, as described in the background.

Assets are defined as key components including sensors (e.g., water quality probes), gateways, communication protocols (e.g., MQTT, CoAP, LoRaWAN), and data flows to cloud platforms. Vulnerabilities are identified stemming from protocol weaknesses, such as lack of native encryption in Zigbee or resource constraints limiting AES implementation on MCUs.

Threat taxonomy is derived using the STRIDE framework, applied per-element to decompose the architecture into trust boundaries. For instance, DDoS threats map to Denial of Service on network layers, while SQL injection targets Tampering at application layers.

The network setup is visualized using PyTM, a Python-based threat modeling tool that generates data flow diagrams (DFDs), sequence diagrams, and threat reports from code definitions [50] . PyTM scripts define boundaries (e.g., external internet, trusted sensor zone), external entities (e.g., attacker), processes (e.g., gateway authentication), and data stores (e.g., sensor logs), automatically enumerating STRIDE threats [50].

All identified threats and attacks are validated and parameterized using the real IoT dataset from Edge-IIoTset [10], ensuring simulations reflect observed attack patterns (e.g., HTTP floods, MITM ARP spoofing) rather than abstractions.

3.4 Security Control Identification and Mitigation Strategy Design

3.4.1 NIS2 Article 21 Compliance Mapping

Addressing RQ3 requires making the connection between STRIDE threats, ML-based countermeasures, and NIS2 obligations explicit rather than general. The mapping process works as follows.

Each of the six STRIDE threat categories identified in Phase 2 is reviewed against the ten subclauses of NIS2 Article 21(2) [13]. Where a threat has direct implications for a specific security obligation, for example, a Denial of Service threat at the network layer implicates the availability and business continuity requirements under Article 21(2)(c). That clause is assigned to the threat. Threats with cross-cutting implications receive multiple clause assignments. The ENISA Technical Implementation Guidance [11] is used to interpret the practical intent of each clause and avoid over-broad mappings.

Once the mapping is established, a second column is added for each threat: the specific ML-based countermeasure that addresses it, and the performance threshold that countermeasure must meet to be considered technically sufficient. For instance, a Random Forest classifier targeting DDoS traffic (Denial of Service, network layer) satisfies Article 21(2)(c) if it achieves an F1-score above a defined threshold on the Edge-IIoTset test set *and* its memory footprint fits within gateway hardware limits. This makes the compliance assessment evidence-based rather than descriptive.

The resulting mapping table will be presented in the Security Analysis chapter (Chapter 4) and will contain: the STRIDE threat category, the affected IoT layer, the corresponding NIS2 Article 21(2) subclause(s), the proposed ML countermeasure, and the RQ2 performance result that supports the compliance claim. Where a countermeasure's measured performance falls short, for example, if a model achieves high F1 on the server but cannot be quantized to fit on gateway hardware then the gap is flagged explicitly as a compliance limitation rather than glossed over.

3.5 Machine Learning for intrusion detection

3.5.1 Selection of Machine Learning Algorithm

Algorithm selection was guided by three criteria applied in order: deployability on constrained hardware, detection accuracy on IoT attack traffic, and interpretability of results for NIS2 compliance purposes.

Classical supervised classifiers(Random Forest, Decision Tree, Logistic Regression, and Naive Bayes) were chosen as the primary focus because they can realistically run within the 4-32 KB RAM budget of the target sensor hardware [28], [37]. Among these, Random Forest was prioritized because its ensemble structure provides robustness against overfitting on imbalanced datasets and handles the high-dimensional feature space of network traffic without extensive manual preprocessing [28]. A scikit-learn Decision Tree model with a depth limit of 5-8 levels produces an exportable model of roughly 1-5 KB, which fits on a

gateway microcontroller. Logistic Regression at 4 KB is even more compact [28], though it performs less well on non-linearly separable attack patterns.

CNN and ANN models were included to establish performance upper bounds, representing what is achievable when detection is offloaded to a gateway or cloud server rather than running at the sensor edge. These models require 10-100 MB of RAM in standard form [37], which puts them well out of reach of sensor nodes. To bridge this gap, the experimental setup will evaluate post-training quantization (8-bit integer weights) and parameter pruning as compression strategies. Quantization typically reduces model size by 4× with less than 1% accuracy loss on classification tasks [37], and is a standard technique for deploying neural networks on microcontroller-class hardware. If a quantized CNN model can be reduced below the gateway RAM limit (256 MB), it becomes a viable edge option; if not, it operates in the cloud tier of a hybrid architecture.

This layered approach directly addresses the hardware constraint problem: classical models are deployed at the sensor or gateway layer, and deep learning models — compressed or not — operate at the cloud layer where resources are available. The comparison between the two tiers quantifies the accuracy-resource trade-off for RQ2.

3.5.2 Experimental Procedure and Setup

Both datasets go through a common preprocessing pipeline before model training. For Edge-IIoTset, this involves dropping columns with near-zero variance, encoding categorical protocol fields, standardizing numerical features to zero mean and unit variance, and handling missing values through median imputation. The water quality dataset is preprocessed separately: readings are resampled to a consistent time step, z-score normalization is applied per parameter, and a sliding window of 20 consecutive readings is used as the input to the anomaly detection model.

The experimental environment runs on a Proxmox virtual machine with 8 vCPU cores and 16 GB RAM, which provides a controlled and reproducible setting without affecting any real infrastructure [10]. All experiments are implemented in Python using scikit-learn for classical classifiers and TensorFlow/Keras for the CNN and ANN models. Model training, evaluation, and compression steps are managed in Jupyter notebooks to ensure the full pipeline is reproducible.

The two experimental tracks proceed as follows:

1. **Network-level intrusion detection (Edge-IIoTset):** The dataset is split 70/30 for training and testing, with stratified sampling to preserve class distribution. Each classifier is trained on the full feature set, and a separate run uses only the 15 most important features selected by Random Forest's feature importance scores, to simulate reduced-resource inference. After training, each model's serialized size is measured and compared against the 4-32 KB sensor RAM budget and the 256 MB gateway RAM limit.

2. **Sensor-level anomaly detection (water quality):** An isolation forest and a simple autoencoder are trained exclusively on normal readings. Anomalies are then injected by replacing a random 5% of readings with values outside the 99th percentile of each

parameter's distribution. Detection performance is measured at multiple contamination thresholds to produce a precision-recall curve.

3.6 System evaluation

3.6.1 Evaluation Metrics and NIS2 Alignment

The choice of evaluation metrics was deliberate. Standard accuracy alone is not suitable for intrusion detection datasets because attack traffic is typically a small fraction of total traffic, a classifier that labels everything as benign can easily score above 95% accuracy while detecting zero attacks [37]. All models in this study are therefore evaluated using:

- **F1-score (macro and per-class):** the harmonic mean of precision and recall, which penalizes both false positives and false negatives equally and is not inflated by class imbalance.
- **Balanced accuracy:** the average of per-class recall rates, giving equal weight to each attack type regardless of how frequently it appears in the dataset [37].
- **Detection latency:** average inference time per sample, measured on the VM to indicate whether the model speed is compatible with real-time gateway operation.
- **Model memory footprint:** the serialized model size in kilobytes, compared against the sensor and gateway RAM thresholds.

After the experimental results are collected, each model's performance is reviewed against the NIS2 Article 21(2) mapping produced in Phase 3. For each NIS2 clause, the question asked is: does the corresponding ML-based countermeasure demonstrate sufficient detection reliability (measured by F1-score) and deployability (measured by memory footprint) to satisfy the clause in a real environmental sensor deployment? This direct link between ML results and NIS2 clause assessment is how RQ2 and RQ3 connect in the final analysis.

4 | Security Analysis and Framework Design

If a prototype system has been developed, this needs to be described here. Replace "..." in the title with the name of your system or something descriptive of your work. Some hints for writing this chapter:

Fatiha note: Scope definition of your specific system (used architecture) The threat collection process (datasets, mittre, literature, cvss database) The full STRIDE classification Likelihood and impact assessment, whether ML can detect those threats RQ3 Proposes a framework that addresses those threats and checks it against the law. three main sections: 1) Section: Threat Taxonomy Development. 2) ML-Based Intrusion Detection and 3) Security Framework Design and NIS2/CRA Mapping (Classify threats (STRIDE) Identify attack techniques (MITRE ATT&CK) Propose mitigations (MITRE D3FEND) Validate against regulation (NIS2 / CRA)

– from previous method moved here:

4.0.1 Dataset Description

Analysis utilizes 14 pcap capture files representing real-world cyber attacks: - DDoS variants (HTTP, ICMP, TCP SYN, UDP floods) - MITM (ARP spoofing), port scanning, vulnerability scanning - Application attacks (SQLi, XSS, password attacks, ransomware)

4.0.2 Threat Classification

Each of the 14 pcap attacks was systematically classified using STRIDE methodology:

Pcap Attack	**STRIDE Category**	**IoT Layer**	**Environmental Impact**
Backdoor attack	Repudiation	Application	Persistent unauthorized gateway access
DDoS HTTP Flood	Denial of Service	Network	Gateway API unavailable
DDoS ICMP Flood	Denial of Service	Network	Sensor data routing blocked
DDoS TCP SYN Flood	Denial of Service	Network	Connection table exhaustion
DDoS UDP Flood	Denial of Service	Network	Bandwidth saturation
MITM (ARP Spoofing + DNS)	Spoofing	Physical	False water quality readings
OS Fingerprinting	Information Disclosure	Physical / Network	Device inventory exposed
Password attacks	Elevation of Privilege	Application	Admin dashboard access
Port scanning attack	Information Disclosure	Network	Open services discovered
Ransomware attack	Denial of Service	Application	Historical data encrypted
SQL injection attack	Tampering	Application	Environmental database corruption
Uploading attack	Elevation of Privilege	Application	Malware persistence installed
Vulnerability scanner attack	Information Disclosure	Network	Exploitable services identified
XSS attacks	Information Disclosure	Application	Admin session hijacking

Table 4.1: STRIDE classification of real world attack dataset

4.0.3 NIS2 Article 21 Compliance Mapping

Regarding NIS2 and our taxonomy, the mapping for each STRIDE category to NIS2 Article 21(2) [13] for our water quality monitoring scenario are presented below, where compromised sensor data can directly affect public health [12].

Repudiation - Clauses (b) and (i): A backdoor can silently alter water quality logs without anyone noticing [28]. Clause (b) requires incident detection and response, which needs proper audit logging to work [13] [11] . Clause (i) requires access control, so role-based access on sensor interfaces is a direct NIS2 obligation [13].

Denial of Services - Clauses (a) and (b): DDoS floods can cut off sensor readings, meaning contamination could go undetected [28]. Clause (a) requires risk analysis, so DDoS must be identified as a gateway risk with rate limiting as a countermeasure [13] [11]. Clause (b) requires incident handling, so ML-based detection and escalation steps are needed when data stops arriving [6].

Spoofing - Clauses (b) and (h): MITM attacks can inject fake sensor readings that hide real contamination [25]. Clause (h) explicitly requires encryption, so mutual TLS on sensor-to-

gateway channels directly fulfils this [13] [11]. Clause (b) requires detecting falsified readings before they reach the platform [27].

Information Disclosure - Clauses (a) and (e): Port scanning and XSS expose network details attackers use to plan bigger attacks [30]. Clause (a) requires minimizing attack surface as part of risk analysis [13] [11]. Clause (e) requires vulnerability handling, so patch management and output encoding are direct obligations [42].

Tampering- Clauses (a) and (e): SQL injection can alter water quality records, hiding contamination events in reports [29]. Clause (e) requires secure development, making parameterized queries and least-privilege accounts direct obligations [13] [11]. Clause (a) requires SQL injection to be part of the risk register and penetration testing [21].

Elevation of Privilege - Clauses (i) and (j): Password attacks and malicious uploads can give full admin control, letting attackers disable sensors or change alert thresholds [29]. Clause (i) requires access control, so least-privilege accounts and restricted uploads are a direct obligation [13] [11]. Clause (j) explicitly names MFA as a required measure for the monitoring dashboard [13].

Table 4.2 summarizes the full mapping of the combination for all six STRIDE categories, corresponding attacks and the NIS2 Article 21(2) clauses they map:

3-Layer Architecture Mapping

Attacks mapped to IoT reference model:

- **Physical Layer (2 attacks):** MITM ARP, OS Fingerprinting
- **Network Layer (6 attacks):** DDoS variants, Port/Vulnerability Scanning
- **Application Layer (6 attacks):** SQLi, XSS, Ransomware, Password attacks

—

This chapter presents the technical implementation of our security framework. We define our specific system arthitecture, explain how we have collected threat information from multiple scores, show how complete STRIDE classification, assess both likelihood and impact of each threat, evaluate capabilities of ML detection and propose a framework that complies with NIS2 regulations.

System Scope and Architecture: We are analyzing a water quality monitoring system that follows the standard three layer IoT architecture [14], [17], [20]. Our analysis applies to actual systems because this architecture pattern appears in real environmental monitoring deployments.

Physical layer: Temperature, dissolved oxygen, turbidity and pH can be measured by water quality sensors [12], [20]. These sensors have limited hardware 8-16 MHz CPUs with just 4-32 KB RAM and 32-256 KB storage [14], [16]. They communicate through short range wireless protocols like bluetooth low energy, Zigbee or LoRa [18]. They are generally deployed in remote locations with infrequent maintenance access and that is their key constraint.

Network layer: Gateways gather data from multiple sensors and transfer it to the cloud [19]. They consist more resources than sensors, typically 50-200 MHz CPUs with 128-512 KB RAM and this extra power allow us to run more sophisticated security measures on gateways [22]. They use WiFi or cellular networks to connect to cloud and MQTT over TLS for cloud communication and CoAP over DTLS for sensor collection [22], [18].

Application layer: Data processing, storage and visualization are handled by cloud platform [23]. Web dashboards are accessed by environmental engineers, public health officials, regulators to monitor water quality in real time.

Threat collection process: We collected threats from several different sources to ensure comprehensive coverage.

Edge-IIoT dataset [10]: They dataset contains actual IoT attack traffic. This includes 14 attas with millions of label packets for example: DDoS floods, reconnaissance attack, vulnerability scanning, man in the middle attacks, application attacks and malware. We are looking at attacks that actually happened in IoT networks, not just theoretical possibilities.

Academic literature [14], [42], [45]: Several IoT security papers have been review to find threats specific to resource constrained devices and environmental monitoring. This particularly relevent to battery powered sensors in remote locations for example energy depletion attacks [14], physical tampering [25], false data injection [40] and protocol vulnertabilities [18].

MITRE ATT&CK for Industrial Control Systems (ICS) [35]: This framework provides structured threat intelligence on attack techniques for industrial control systems. Environmental monitoring isn't industrial control. However they share key traits for examnple remote equipment, operational technology focus. This makes ICS attack techniques relevant for our analysis.

CVSS Databse [34]: Known vulnerabilities in IoT software have been analyzed for example MQTT brokers, web frameworks, Bluetooth and Zigbee stacks. This verifies which vulnaribilites are actually being found to IoT components and their severity levels.

STRIDE Threat Classification: We classified all 14 attacks using STRIDE methodology [21] [33], mapping each to threat categories, IoT layers, environmental impacts, and risk levels.

Spoofing attacks let attackers impersonate legitimate sensors through ARP spoofing [25] [27]. This means injecting false readings that hide contamination or trigger unnecessary alarms.

Tampering attacks compromise data integrity through SQL injection [29]. Attackers can delete contamination logs, modify historical records or change sensor calibrations, undermining regulatory compliance and public health decisions.

Repudiation attacks use backdoors to modify data without leaving audit trails [28]. This makes investigating incidents impossible since all evidence gets erased.

Information disclosure attacks expose network details through scanning and XSS [30]. This reconnaissance enables targeted attacks against discovered vulnerabilities.

Denial of service attacks overwhelm gateways with DDoS floods [14] [41], preventing sensor data from reaching monitoring systems during emergencies.

Elevation of privilege attacks use password attacks or malicious uploads to gain admin access [29]. Attackers can then disable sensors, change alert thresholds or manipulate data processing.

Likelihood and impact assessment: We assessed each threat's likelihood and impact following risk frameworks [34] [36] to prioritize mitigation efforts.

Likelihood criteria: High likelihood means the attack is well-known, easy to execute and commonly seen in IoT deployments (like DDoS or port scanning). Medium likelihood requires moderate technical skill or specific conditions. Low likelihood needs advanced skills or rare circumstances.

Impact criteria: Critical impact means compromised water quality data could cause public health emergencies or system unavailability during contamination events. High impact means significant operational disruption or data integrity compromise. Medium impact is temporary degradation. Low impact is reconnaissance only.

Priority ranking: Critical priority includes MITM attacks (medium likelihood, critical impact) and ransomware (low likelihood, critical impact). High priority includes all DDoS variants, SQL injection, and password attacks (high likelihood or high impact). This prioritization guides resource allocation for mitigation [34].

Machine Learning based detection capability: Considering other observable features and resource constraints we evaluated wheather machine learning can detect each threat type.

Network level attacks are highly detectable. Distinctive traffic patterns are created by DDoS floods which ML models detect easily [28], [37]. 99.99% accuracy on volumetric attacks are achieved by Random Forest [28]. Lightweight classifiers for example Decision Trees and Logistic Regression reach 94-98% which are suitable for gateway deployment [28], [37]. Port and vulnerability scanning create recognizable sequential patterns detectable with over 95% accuracy [28].

Payload inspection are required for Application level attacks. SQL injection and XSS require analyzing request content [5]. By learning payload patterns over 99% accuracy is achieved by Deep learning models (CNN, LSTM) [5], [7]. However, it requires cloud resources. Password attacks show up in authentication logs as unusual patterns of failed login attempts. Anomaly detection catches these with 90-95% accuracy [29].

Man in the middle attacks are challenging but detectable. MAC address inconsistencies are created by ARP spoofing [25].ARP spoofing creates MAC address inconsistencies [25]. We can catch this by watching ARP tables to see if the same IP address suddenly points to different MAC addresses. This detection method works with 85-92% accuracy [27]. For malware like ransomware and backdoors, we need host-based detection. This means monitoring what files get accessed and how processes behave on the system. This approach achieves 95-98% accuracy [5].

Hybrid deployment strategy : Sensors run ultra lightweight models for example Logistic Regression that catch obvious attack [39] [37]. Gateways run medium weight models for example Random Forest and Decision Trees for comprehensive network detection. For sophisticated application layer attacks, cloud runs deep learning and this approach achieves over 99% overall detection [39] [37].

Security framework and NIS2 compliance:

STRIDE to NIS2 mapping: Table 4.2 summarizes the full mapping of the combination for all six STRIDE categories, corresponding attacks and the NIS2 Article 21(2) clauses they map:

STRIDE category	**Pcap Attacks**	**NIS2 Art. 21(2)**	**Requirement**	**NIS2-Aligned Mitigation**
Repudiation	Backdoor attack	(b), (i)	Incident handling; access control and asset management	Audit logging; role-based access control
Denial of Service	DDoS HTTP, ICMP, TCP SYN, UDP Flood; Ransomware	(a), (b)	Risk analysis; incident handling	ML-based detection; rate limiting at gateway
Spoofing	MITM (ARP Spoofing + DNS)	(b), (h)	Incident handling; cryptography and encryption	Mutual TLS on sensor-to-gateway channels; anomaly detection on sensor readings
Information Disclosure	OS Fingerprinting, Port scanning, Vulnerability scanning, XSS	(a), (e)	Risk analysis; vulnerability handling and disclosure	Disable unnecessary ports; patch management; output encoding on dashboard
Tampering	SQL injection	(a), (e)	Risk analysis; secure development and maintenance	Parameterized queries; least-privilege database accounts
Elevation of Privilege	Password attacks, Uploading attack	(i), (j)	Access control and asset management; multi-factor authentication and secure communications	MFA on dashboard; least-privilege accounts; restrict file uploads

Table 4.2: Summary of STRIDE to NIS2 mapping

Mitigations aligned with NIS2 Directive (EU) 2022/2555, Article 21(2) [13] and ENISA Technical Implementation Guidance [11].

Defensive Techniques (MITRE D3FEND): We mapped our defenses to the MITRE D3FEND framework. Network Traffic Analysis detects DDoS attacks and scanning activities [41]. Credential Hardening prevents password attacks [13]. Message Authentication stops man in the middle attacks [27]. Input Validation blocks SQL injection and XSS attacks [29]. File Analysis catches malware before it can execute [5].

For Cyber Resilience Act compliance [13], we address three main requirements. Secure by design means we disable default credentials, enable automatic updates, and use secure boot. Vulnerability handling means we have coordinated disclosure processes, deploy patches within 14 days and run automated scanning. Security updates for lifetime means we commit

to 5 years of support, provide over the air updates and include rollback mechanisms if something goes wrong.

We checked if this actually works given the resource limits. Sensors with 4-32 KB RAM can handle lightweight ECC authentication and Logistic Regression detection. Gateways with 128-512 KB RAM can run Random Forest detection, TLS termination and log aggregation. Cloud infrastructure can handle everything including deep learning models. This shows that NIS2 and CRA compliance is actually achievable even for constrained IoT devices [19] [39].

- Use figures!
- Figures should either be drawn by you, or carefully cited in the caption.
- Figures should always be referenced in the text, and explained in the text what they represent/contain.
- You should start with a structural overview of your prototype/system/algorithm/Framework.
- Show clearly what parts you have created, and which parts that were already existing when you started. Remember that aseembling existing components can also be a contribution.
- Avoid programming code and strangely-sounding variable/function names.
- You are free to call a module something else than what it is called in the source code.
- Always have the reader in mind when writing. Be pedagogic.

–

4.0.4 UMAP of attacks

UMAP (Uniform Manifold Approximation and Projection) visualisation of 7,000 network packets across 14 attack types from the Edge-IIoTset dataset, projected from a 29-dimensional feature space onto two dimensions. Each dot represents a single network packet, and the colour indicates the attack type. The axes have no physical unit, only the relative positions and distances between points carry meaning, where proximity indicates similar network behaviour. Several findings emerge: (1) DDoS variants (HTTP, ICMP, TCP SYN, UDP) form separate, tight clusters spread across the projection, confirming that each flooding technique produces a distinct traffic pattern despite sharing the same attack goal; (2) Fingerprinting and Port Scanning form compact, isolated groups, reflecting their structured and repetitive probing behaviour; (3) Injection-based attacks (SQL Injection, XSS) and Uploading partially overlap in the centre of the projection, suggesting these attacks share similar TCP session characteristics as they all exploit application-layer vulnerabilities; (4) MITM appears as scattered points, consistent with its nature of mimicking legitimate traffic to avoid detection. The clear separation between most attack types indicates that unsupervised dimensionality reduction techniques such as UMAP can effectively distinguish attack categories in IoT network traffic, supporting their use as a complementary tool for intrusion detection and threat classification in water environment monitoring systems.

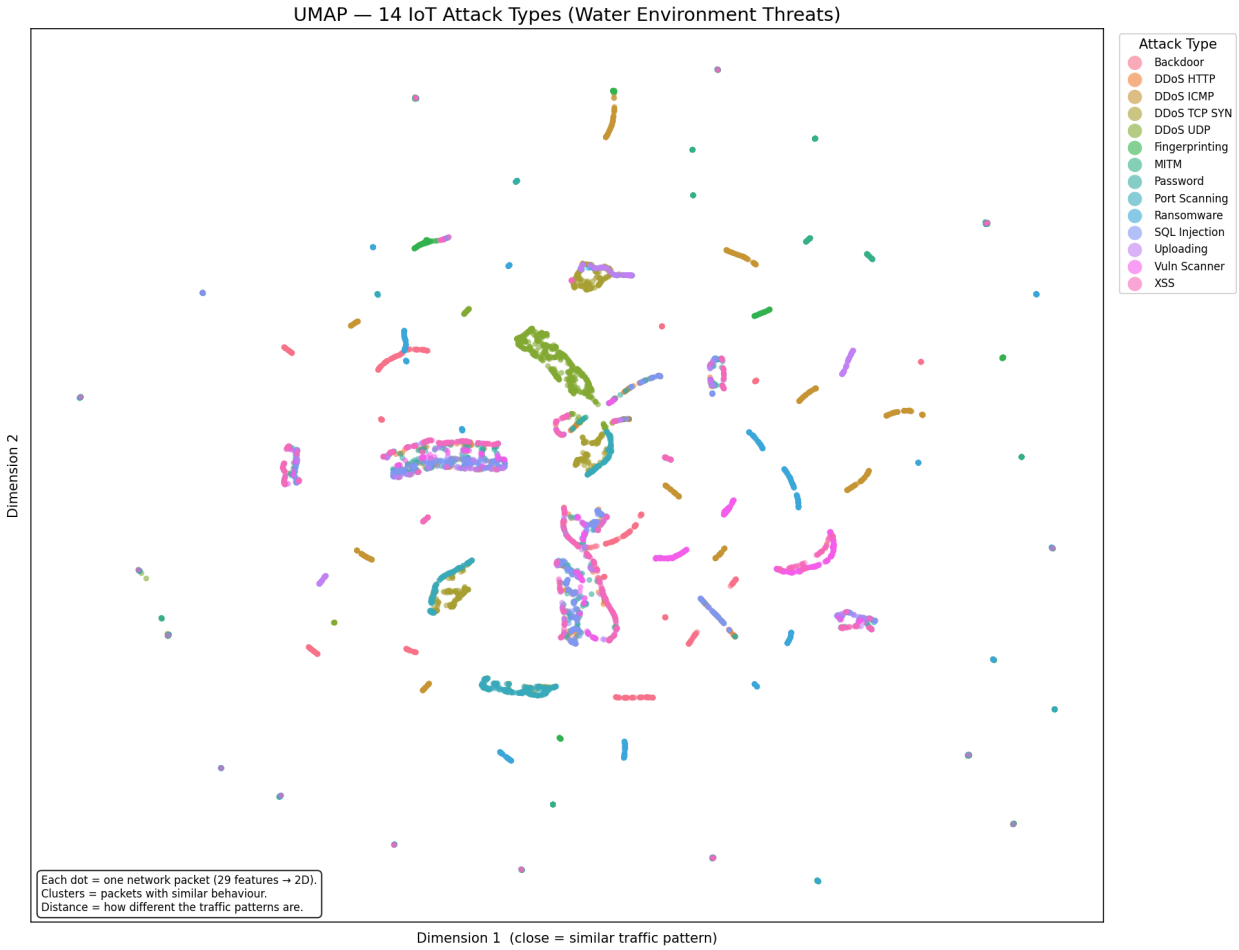

Figure 4.1: UMAP of attacks

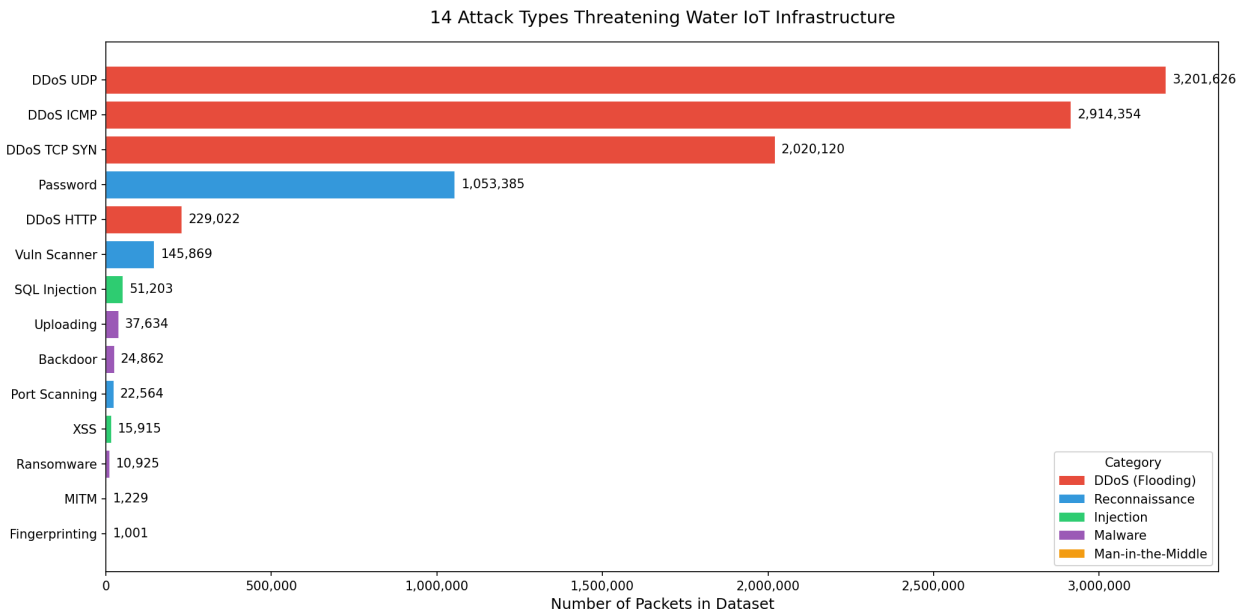

Figure 4.2: Heatmap of attacks

4.0.5 Heatmap of attacks

The heatmap presents the 14 attack types extracted from the Edge-IIoTset dataset [10] that pose a threat to the water environment IoT monitoring system. Volumetric DDoS attacks dominate the dataset. DDoS UDP flooding accounts for the largest share with approximately 3.2 million packets, followed by DDoS ICMP (2.9M) and DDoS TCP SYN (2.0M). This distribution reflects the nature of flooding attacks, which generate a high volume of traffic to overwhelm network resources. In a water IoT deployment, such attacks could disrupt communication between field sensors and the IoT gateway, potentially causing loss of real-time monitoring data. Password attacks represent the most prominent reconnaissance threat (1.05M packets), while vulnerability scanning (145K) and port scanning (22K) indicate active probing of the network. Application-layer attacks such as SQL injection (51K) and cross-site scripting (XSS, 16K) target the cloud-side components of the architecture. Malware-related attacks, including uploading (37K), backdoor (24K), and ransomware (10K), pose risks to the integrity of both the gateway and cloud servers. MITM and OS fingerprinting have the lowest packet counts (1,229 and 1,001 respectively), but remain critical threats as they can enable data interception and system profiling with minimal traffic.

5 | Results and discussion

Fatiha note: What the ML models detected Performance metrics Findings against the taxonomy

The Results and discussion section presents a detailed and objective description of the results. This can be done by showing tables, figures which are numbered and given explanatory figure/table texts. Figure numbering is below the figure while the tables get their numbering above. If tables or figures are too big or too many, the most interesting are added in this section and the rest must be placed in the appendix, see Appendix. In graphs don't forget to state units and to use the figure area optimal. Avoid strange/hard reading colours and symbols; it must be easy for the reader to understand the graphs. This section must also conclude the results and findings (or if too extensive in a new section for result discussion). The purpose is to discuss and analyse the meaning of the results related to the theoretical framework, related jobs and methodology. Questions to be asked when you write this section: what do the readings say, how likely are they, can they be generalized, how significant are the results, outliers, etc. In this part, personal reflections are allowed.

Conclusion

The final aim of the study is to make conclusions from what is analysed, implement-ed, tested or measured. Discuss and answer all the aims and questions formulated in the introduction. The conclusions drawn should refer to the initial aims, objectives, literature and problems. The validity of the conclusions should also be discussed and evaluated.

5.0.1 Future Work and Research

It is common to conclude with a section on future work, either as part of the conclusion section or as a new chapter. It is sometimes important to recognize how the project can move forward in solving future problems.

5.0.2 Critical Discussion

Personal reflections and personal experiences during the work.

5.0.3 Generalization of the result

Discuss how general the result is and if they can be useful in other areas. How unique is this study?

Bibliography

[1] S. Nižetić, P. Šolić, and L. Patrono, "Internet of things (iot): Opportunities, issues and challenges towards a smart and sustainable future," *Journal of Cleaner Production*, vol. 274, p. 122877, 2020.

[2] M. Abrams and J. Weiss, "Malicious control system cyber security attack case study–maroochy water services, australia," tech. rep., MITRE Corporation, July 2008.

[3] G. Geyer, "Cyberattack on norwegian dam highlights password exposure risks." Claroty Blog, June 2025.

[4] M. J. Farooq and Q. Zhu, "Modeling, analysis, and mitigation of dynamic botnet formation in wireless IoT networks," *IEEE Transactions on Information Forensics and Security*, vol. 14, pp. 2412–2426, Sept. 2019.

[5] T. Hasan *et al.*, "Securing industrial internet of things against botnet attacks using hybrid deep learning approach," tech. rep., La Trobe University, Mar. 2022. OPAL (Open@LaTrobe).

[6] P. Mahadevappa, R. K. Murugesan, R. Al-Amri, R. Thabit, A. H. Al-Ghushami, and G. Alkawsi, "A secure edge computing model using machine learning and IDS to detect and isolate intruders," *MethodsX*, p. 102597, Feb. 2024.

[7] B. Ullah, S.-U.-R. Massan, M. A. Rehman, and R. A. Khan, "Cyber security intrusion detection using a deep learning method," *Mehran University Research Journal of Engineering and Technology*, vol. 44, pp. 69–74, Jan. 2025.

[8] B. Leander, A. Čaušević, and H. Hansson, "Applicability of the IEC 62443 standard in industry 4.0 / IIoT," in *Proceedings of the 14th International Conference on Availability, Reliability and Security*, Aug. 2019.

[9] DNV, "Leverage IEC 62443 for EU NIS2 directive compliance." DNV, 2024.

[10] M. A. Ferrag, "Edge-iiotset: Cyber security dataset of iot & iiot." Kaggle dataset, 2023. Version as of access date.

[11] European Union Agency for Cybersecurity (ENISA), "Technical implementation guidance on cybersecurityrisk management measures under the nis2 directive," tech. rep., ENISA, 2025.

[12] W.-Y. Chung and J.-H. Yoo, "Remote water quality monitoring in wide area," *Sensors and Actuators B: Chemical*, vol. 217, pp. 51–57, 2015. Selected Papers from the 15th International Meeting on Chemical Sensors, 16-19 March 2014, Buenos Aires, Argentina.

[13] European Parliament and Council of the European Union, "Directive (eu) 2022/2555 of the european parliament and of the council of 14 december 2022 on measures for a high common level of cybersecurity across the union." Official Journal of the European Union (OJ L 333, 27 Dec 2022).

[14] I. Andrea, C. Chrysostomou, and G. Hadjichristofi, "Internet of things: Security vulnerabilities and challenges," in *2015 IEEE Symposium on Computers and Communication (ISCC)*, pp. 180–187, 2015.

[15] I. Zhang, "Real-time water quality data." Kaggle dataset, 2020. Version as of access date.

[16] F. Jan, N. Min-Allah, S. Saeed, S. Z. Iqbal, and R. Ahmed, "Iot-based solutions to monitor water level, leakage, and motor control for smart water tanks," *Water*, vol. 14, no. 3, 2022.

[17] Y. Song, *Security in Internet of Things*. PhD thesis, KTH Royal Institute of Technology, 2013.

[18] L. K. Ketshabetswe, A. M. Zungeru, M. Mangwala, J. M. Chuma, and B. Sigweni, "Communication protocols for wireless sensor networks: A survey and comparison," *Heliyon*, vol. 5, no. 5, p. e01591, 2019.

[19] A. Overmars and S. Venkatraman, "Towards a secure and scalable iot infrastructure: A pilot deployment for a smart water monitoring system," *Technologies*, vol. 8, no. 4, 2020.

[20] M. Pule, A. Yahya, and J. Chuma, "Wireless sensor networks: A survey on monitoring water quality," *Journal of Applied Research and Technology*, vol. 15, no. 6, pp. 562–570, 2017.

[21] V. Casola, A. De Benedictis, M. Rak, and U. Villano, "Toward the automation of threat modeling and risk assessment in iot systems," *Internet of Things*, vol. 7, p. 100056, 2019.

[22] C. Sharma and N. K. Gondhi, "Communication protocol stack for constrained iot systems," in *2018 3rd International Conference On Internet of Things: Smart Innovation and Usages (IoT-SIU)*, pp. 1–6, 2018.

[23] J. Gubbi, R. Buyya, S. Marusic, and M. Palaniswami, "Internet of things (iot): A vision, architectural elements, and future directions," *Future Generation Computer Systems*, vol. 29, no. 7, pp. 1645–1660, 2013. Including Special sections: Cyber-enabled Distributed Computing for Ubiquitous Cloud and Network Services & Cloud Computing and Scientific Applications — Big Data, Scalable Analytics, and Beyond.

[24] P. Parihar, "Attacks in wireless networks," 2011. Accessed: 2026-02-26.

[25] G. Vinicio and N. Geovanni, "Strategies of iot in wireless sensor," in *Lecture Notes in Networks and Systems*, 2024.

[26] S. Latif, D. Djenouri, Z. Idrees, and Z. Zou, "Hardware security modules for secure communications in the industrial internet of things," *IEEE Communications Surveys and Tutorials*, 2026.

[27] G. Kurt and Ö. Cepheli, "Physical layer security of cognitive iot networks," in *Internet of Things*, 2020.

[28] G. Samara, M. A. Fadda, A. Al-Mohtaseb, R. Alazaidah, A. M. N., M. Odeh, M. Aljaidi, M. M. Shuaib, and M. Kanan, "Deep learning approaches for malware detection in the industrial internet of things: A comprehensive analysis," in *2024 25th International Arab Conference on Information Technology (ACIT)*, pp. 1–7, 2024.

[29] A. Almuqren, "Cybersecurity threats, countermeasures and mitigation techniques on the iot: Future research directions," *Journal of Cyber Security and Risk Auditing*, 2025.

[30] R. Kaksonen, K. Halunen, and J. Roning, "Vulnerabilities in iot devices, backends, applications, and components," in *International Conference on Information Systems Security and Privacy*, 2023.

[31] A. Rekeraho, D. T. Cotfas, T. C. Balan, P. A. Cotfas, R. Acheampong, and E. Tuyishime, "Cybersecurity threat modeling for iot-integrated smart solar energy systems: Strengthening resilience for global energy sustainability," *Sustainability*, vol. 17, no. 6, 2025.

[32] J. Beyer, "Adam shostack on threat modeling," *IEEE Software*, vol. 37, no. 6, pp. 110–112, 2020.

[33] Microsoft Corporation, "Threats - microsoft threat modeling tool," 2026.

[34] Joint Task Force, "Risk management framework for information systems and organizations: A system life cycle approach for security and privacy," tech. rep., National Institute of Standards and Technology, dec 2018.

[35] M. Jbair, B. Ahmad, C. Maple, and R. Harrison, "Threat modelling for industrial cyber physical systems in the era of smart manufacturing," *Computers in Industry*, vol. 137, p. 103611, 2022.

[36] European Union Agency for Cybersecurity (ENISA), *Compendium of Risk Management Frameworks with Potential Interoperability: Supplement to the Interoperable EU Risk Management Framework Report*. Luxembourg: Publications Office of the European Union, 2022.

[37] L. Yang, J. Li, L. Yin, Z. Sun, Y. Zhao, and Z. Li, "Real-time intrusion detection in wireless network: A deep learning-based intelligent mechanism," *IEEE Access*, vol. 8, pp. 170128–170139, 2020.

[38] M. H. Alsulami, "An ai-driven model to enhance sustainability for the detection of cyber threats in iot environments," *Sensors*, vol. 24, no. 22, 2024.

[39] Y. K. Aluri and S. Tamilselvan, "Machine learning-driven cross-layer IDS architecture for next-generation IoT networks," *International Journal of Innovative Technology and Interdisciplinary Sciences*, vol. 8, pp. 707–733, Oct. 2025.

[40] P. Grover and S. K. Prasad, "A blockchain based decentralized application system for VANET false data injection attack (FDIA) detection," 2024. Preprint available on ResearchGate: https://www.researchgate.net/publication/367291135.

[41] F. S. Dantas Silva, E. Silva, E. P. Neto, M. Lemos, A. J. Venancio Neto, and F. Esposito, "A taxonomy of DDoS attack mitigation approaches featured by SDN technologies in IoT scenarios," *Sensors*, vol. 20, no. 11, p. 3078, 2020.

[42] S. Rizvi, A. Kurtz, J. Pfeffer, and M. Rizvi, "Securing the internet of things (iot): A security taxonomy for iot," in *2018 17th IEEE International Conference On Trust, Security And Privacy In Computing And Communications/ 12th IEEE International Conference On Big Data Science And Engineering (TrustCom/BigDataSE)*, pp. 163–168, 2018.

[43] N. Maheswaran, G. Logeswari, S. Bose, and T. Anitha, "A critical review on intrusion detection systems in iot based on ml approach:a survey," in *2023 2nd International Conference on Smart Technologies and Systems for Next Generation Computing (ICSTSN)*, pp. 1–8, 2023.

[44] L. Wüstrich, M.-O. Pahl, and S. Liebald, "Towards an extensible iot security taxonomy," in *2020 IEEE Symposium on Computers and Communications (ISCC)*, pp. 1–6, 2020.

[45] H. Sebestyen, D. E. Popescu, and R. D. Zmaranda, "A literature review on security in the internet of things: Identifying and analysing critical categories," *Computers*, vol. 14, no. 2, 2025.

[46] Z. Alwaisi, T. Kumar, E. Harjula, and S. Soderi, "Securing constrained iot systems: A lightweight machine learning approach for anomaly detection and prevention," *Internet of Things*, vol. 28, p. 101398, 2024.

[47] D. N. Jha, K. Alwasel, A. Alshoshan, X. Huang, R. K. Naha, S. K. Battula, S. Garg, D. Puthal, P. James, A. Zomaya, S. Dustdar, and R. Ranjan, "IoTSim-Edge: A simulation framework for modeling the behavior of internet of things and edge computing environments," *Softw. Pract. Exp.*, vol. 50, pp. 844–867, June 2020.

[48] U. M. Waseem Abbass, Nasim Abbas, "Simedgeai: A deep reinforcement learning framework for simulating task offloading," *ScienceDirect*, 2026.

[49] I. A. Malik and G. Habib, "Ai enabled resource-constrained computing architectures for iot devices," *ICCK Transactions on Machine Intelligence*, vol. 1, no. 3, pp. 138–147, 2025.

[50] OWASP Foundation, "pytm: A pythonic framework for threat modeling." GitHub repository, 2023. Accessed: 2026-03-25.

Glossary and Symbols

ISO he International Organization for Standardization is an international standard development organization composed of representatives from the national standards organizations of member countries.

NIST NIST is the National Institute of Standards and Technology at the U.S. Department of Commerce.

CPS Cyber-physical systems (CPS) and the Internet of Things (IoT) are both complex platforms that share a common goal of increasing technological reliability, expanding advancement opportunities and exposing areas of untapped potential